

SurveyMonkey: IP Spoofing (English translation)

SurveyMonkey: IP Spoofing - Author not stated, Catch²² (in)security / ChrisJohnRiley.

- Publisher in English: Catch²² (in)security / ChrisJohnRiley
- Published: 2011-04-22
- Original: <<http://blog.c22.cc/2011/04/22/surveymonkey-ip-spoofing/>>
- Current location: <<https://c22blog.wordpress.com/2011/04/22/surveymonkey-ip-spoofing/>>
- Preserved from: <https://c22blog.wordpress.com/2011/04/22/surveymonkey-ip-spoofing/> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content (translated into English)

Machine translation of [2011-c22-in-suit-chrisjohnriley-surveymonkey-ip-spoofing.md](#), which holds the source's own words. Code, payloads, type names, URLs and CVE identifiers were masked before translating and restored after, so they are byte-identical to the original.

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

SurveyMonkey: IP Spoofing | Catch²² (in)security / ChrisJohnRiley

Catch²² (in)security / ChrisJohnRiley

Because we're damned if we do, and we're damned if we don't!

SurveyMonkey: IP Spoofing

Posted by [ChrisJohnRiley](#) on April 22, 2011

It's amazing the things you find when you're not really looking for them!

A few weeks back I was finalizing some of the survey results for my #BSidesLondon talk when I noticed something interesting, if a little strange. When somebody fills out a survey on the [SurveyMonkey](#) website, they record a number of pieces of meta data along with the survey answers. Things like data, time, link used to access the survey, and the IP Address of the personal completing the survey. This final piece of data was the one that really caught my attention, especially when I started seeing a number of [RFC1918](#) addresses in with the mix. That's a bit weird... why, and more interestingly, how are they getting these local addresses.

[[image: image]](<https://c22blog.wordpress.com/wp-content/uploads/2011/04/survey.png>)

A lot of thoughts went through my mind... client-side java checking for local address maybe... something like decloak. Still, that wouldn't account for the fact that only occasional responses had the private address, when others had the public address (about 5-6 in the 100 responses I looked at).

So, firing up Burp Suite, I threw a couple of fake survey responses through to SurveyMonkey for testing and quickly found that remote system was picking up the public internet routable address on all my test responses. No funky JavaScript, no Java (at all), so it must be something in the request from the client to the server. Taking a look at the various options I started playing about with the [X-Forwarded-For](#) and [X-Real-IP](#) request headers and quickly discovered that by setting an X-Forwarded-For header on the survey traffic I could set any IP address I wanted on the response.

```
GET /  
host: surveymonkey.com  
User-Agent: Mozilla/5.0  
**X-Forwarded-For: 127.0.0.1**  
X-Real-IP: 127.0.0.2  
...
```

[\[\[image: image\]\]\(https://c22blog.wordpress.com/wp-content/uploads/2011/04/surveymonkey_127-0-0-11.png\)](https://c22blog.wordpress.com/wp-content/uploads/2011/04/surveymonkey_127-0-0-11.png)

Well that's a bit of fun... I can set RFC1918 addresses... how totally fun, and at the same time useless as well. So taking this one step further, I thought, What would be possible with this. I can spoof the IP address of a person filling out a survey. Well, maybe I could specify a public IP address other than my own in this header too. If they're not checking the string, maybe I can spoof a survey response from somebody who didn't fill it out. Not really BIG impact, but if I fill out an anti-government survey from a Whitehouse IP address, I'm sure it'll cause a bit of a stir. So, let's see if I can fill out this survey from China... after all, if the IP says China, it must be them right

[\[\[image: image\]\]\(https://c22blog.wordpress.com/wp-content/uploads/2011/04/surveymonkey_china.png\)](https://c22blog.wordpress.com/wp-content/uploads/2011/04/surveymonkey_china.png)OMG... China are all up in my survey, APTing me! (1.2.2.2 is one of the [IP ranges assigned to China](#)). Still aside from framing nation states for filling in nasty comments on your surveys, what else can you do with this?

I'm so glad you asked. Well, just because the X-Forwarded-For header is meant for transporting IP addresses of the client, doesn't mean that's what we're going to put in there!

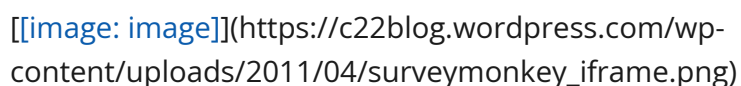
The IP address is returned to the owner of the survey, and as such, is only viewable by authenticated users. I'm sure there are also places where this IP address are returned to administrators, support staff, etc... but that's not something I was able to check. So, how about we put in something other than an IP address. Something simple to prove the point... some kind of alert box maybe.

[\[image: image\]](#)

Well, no. Not because it's filtered though. In the case of the Surveymonkey, the returned data is filtered to 20 characters. Anything longer is stripped. So anything flashy is pretty much out of question. Actually, almost anything interesting is out of scope, unless you happen to own a domain name that's 5 characters long (in total). Sadly, I only own a domain that's 6 characters (c22.cc) which is a pity.

Still, I threw together a quick PoC that triggers an iFrame from another site. An attacker (given a suitable domain name) could use this to load Javascript using script src instead of iframe src. Not really the kind of PoC I was hoping for, but it proves the point I guess.

```
GET /
host: surveymonkey.com
User-Agent: Mozilla/5.0
**X-Forwarded-For: <iframe src=//*aa.bb*>**
...
```

 (https://c22blog.wordpress.com/wp-content/uploads/2011/04/surveymonkey_iframe.png)

I contacted Surveymonkey with the information discovered and they've begun looking into correcting the issue. The question that really interests me is, how many other sites are using the same system and trusting user provided headers. This is something that webapp testers "should" be testing for. Still, there are lots of things that testers "should" be doing!

[Penetration Test, Security](#)

Archived from <http://blog.c22.cc/2011/04/22/surveymonkey-ip-spoofing/>. Rendered offline from the local Markdown copy.